

INCIDENT RESPONSE POLICY

Version 1.0

Revision Date: August 18, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Incident Response Policy
Document ID	POL-IRP-001
Current Version	1.0
Approved Date	August 18, 2026
Approved By	Information Security Steering Committee
Effective Date	August 18, 2026
Next Review Date	August 18, 2027
Classification	Internal
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon material change
Supersedes	N/A
Audience	All personnel, including employees and contractors

APPROVERS AND OWNERS

Name	Role	Information Security Role	Signature	Date
Madhuri Chandoor	Approver	CEO and Founder		August 18, 2026
Praveen Sharma	Owner / Author	Fractional CISO/Security Officer		August 18, 2026

COMPLIANCE

This Policy is authorized by the Information Security Policy (POL-ISP-001) and supports the SOC 2 Trust Services Criteria CC2.2, CC2.3, CC7.3, CC7.4 and CC7.5, HIPAA Security Rule 45 CFR §164.308(a)(6), and GDPR Articles 33 and 34. It is written for a ten-person remote team, where the response roles are held by two or three people and external help is named in advance.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 OVERVIEW AND PURPOSE	5
2 SCOPE	5
3 ROLES AND DEFINITIONS.....	5
4 TERMINOLOGY	5
5 REPORTING AN EVENT	6
6 SEVERITY	6
7 RESPONSE	7
8 NOTIFICATION.....	7
9 RECOVERY AND AFTERWARDS.....	7
10 EXERCISING THE PLAN.....	8
11 RECORDS	8
12 EXCEPTIONS.....	8
13 REFERENCE.....	8
14 DOCUMENT POLICY HISTORY.....	8

1 Overview and Purpose

PromptHalo Technologies (“the Company”) will have incidents. This Policy says how one is recognised, who does what, what gets told to whom and when, and what happens afterwards.

It is written for the Company as it is: ten people, mostly fractional, working remotely. The plan assumes two or three people are available, not a staffed response team, and names outside help rather than pretending internal capacity exists.

2 Scope

This Policy covers security incidents affecting Company or client information, the systems the Company runs, and the access it holds inside client environments. It covers events involving AI and agentic systems on the same terms as any other.

It applies to everyone, including contractors, and to events reported by clients, security researchers or the public.

3 Roles and Definitions

1. "The Company" refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this policy, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this policy and reviews it at least annually. [SOC 2: CC1.2, CC5.3]
4. Incident roles are assigned by name in advance and held on the contact list: the incident lead who runs the response, the Accountable Party who decides on notification, the communications lead who speaks to clients, and the scribe who keeps the timeline. [SOC 2: CC7.4, CC1.3]
5. At the Company's size one person will hold more than one of these. The incident lead and the communications lead are kept separate where two people are available, because the person containing the incident should not also be the one drafting client messages. Where they cannot be, that is recorded in the incident record rather than left implicit. [SOC 2: CC7.4, CC1.3]
6. Outside help is named before it is needed: the external counsel who advises on notification, and an incident responder the Company can call. Their contact details sit on the same list. Naming them in advance is what makes the four roles real at this headcount. [SOC 2: CC7.4, CC9.2]

4 Terminology

The following terms have the meanings given below wherever they appear in this policy.

1. **Accountable Party** — the CEO or, in their absence, the Security Officer, who owns this policy.
2. **Confidential information** — information classified Confidential or Restricted under the Data Classification Policy, including customer data.

3. **Containment** — action taken to stop an incident spreading or continuing, which may precede understanding its cause.
4. **Control** — an activity, automated or manual, performed on a defined cadence that produces evidence it occurred.
5. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.
6. **Event** — something observed that may or may not be an incident, until it has been evaluated.
7. **Incident** — an event that has been evaluated and found to affect, or credibly threaten, the security of Company or client information.
8. **Information Security Steering Committee** — the Company's oversight body for information security. At the Company's current size, the Committee comprises the CEO, and every reference in this policy to a decision, approval, review or report of the Committee is satisfied by a dated written record made or confirmed by the CEO; a formal meeting is not required. [SOC 2: CC1.2, CC1.3]
9. **Personnel** — employees, officers, contractors, consultants, interns and temporary workers of the Company.
10. **Post-incident review** — the recorded look back after an incident, covering what happened, what was done, and what changes follow.
11. **Security Officer** — the individual accountable for day-to-day operation of the security program.
12. **Severity** — the level assigned to an incident under Section 6, which governs the response.
13. **Significant change** — a change meeting the trigger criteria in the Risk Management Policy that requires risk reassessment.
14. **Subservice organization** — a third party whose controls the Company relies upon and which is carved out of the Company's report.

5 Reporting an Event

1. Anything that looks wrong is reported to security@prompthalo.com the same day. Reporting promptly is treated as doing the right thing; the mistake is concealing it, not making it. [SOC 2: CC2.2, CC7.3]
2. Clients, security researchers and the public report through the address published in security.txt. Reports arriving that way are handled exactly as internal ones. [SOC 2: CC7.3, CC2.3]
3. Each report is evaluated by the Security Officer, given a severity, and either declared an incident or closed with the reason recorded. A closed event still leaves a record — the population of events is what shows the process runs. [SOC 2: CC7.3, CC2.1]

6 Severity

Four levels, with triggers rather than judgement so that the level is arguable from the facts.

1. Severity One — client information confirmed exposed, or the service materially unavailable. Severity Two — credible threat to client information, or an agent acting outside its scope on client systems. Severity Three — a Company system affected with no client exposure. Severity Four — a near miss or a control failure with no impact. [SOC 2: CC7.3]
2. Severity is reassessed as understanding improves, and both the original and revised levels stay in the record. Downgrading quietly is how a notification obligation gets missed. [SOC 2: CC7.3]
3. Incidents involving AI or agentic systems are named as incidents on the same scale. The first containment action for an agent is to stop it, before diagnosing why. [SOC 2: CC7.4]

7 Response

1. Containment is proportionate and may be taken before the cause is understood. Every containment action is recorded with the time it was taken — the timeline is the single most useful artifact afterwards. [SOC 2: CC7.4]
2. Evidence is captured before a compromised system is rebuilt, and logs covering the period are preserved beyond their normal retention. Rebuilding first is the commonest way to lose the answer. [SOC 2: CC7.4, CC7.2]
3. The scribe keeps a running timeline: what was seen, what was done, by whom, at what time. At this size a shared document is sufficient and no tooling is required. [SOC 2: CC7.4, CC2.1]

8 Notification

1. The notification obligations in customer agreements are extracted in advance into a notification matrix, with the shortest applicable period governing where several apply. Reading contracts during an incident is how deadlines get missed. [SOC 2: CC2.3, CC7.4 • GDPR Art. 33]
2. The Accountable Party decides on notification, taking advice from the named external counsel where the position is unclear. The decision, its basis and its timing are recorded whether or not notification follows. [SOC 2: CC2.3, CC7.4]
3. Where the Company is a processor, it notifies the controller without undue delay so they can meet their own obligations. [SOC 2: CC2.3 • GDPR Art. 33]

9 Recovery and Afterwards

1. Systems are restored to a known-good state, credentials rotated, and the vector confirmed closed before an incident is called resolved. “It stopped happening” is not confirmation. [SOC 2: CC7.5]
2. A post-incident review is held for every incident at Severity Two or above, and for any incident that reached a client whatever its severity. It covers what happened, what was done, what worked, and what changes follow. [SOC 2: CC7.5]
3. Corrective actions from an incident are recorded in the plan of action maintained under the Information Security Policy, which is the Company's single deficiency population. This Policy

keeps no separate corrective action list — two lists diverge, and the one an auditor samples is always the other one. [SOC 2: CC7.5, CC4.2]

4. Themes across incidents are looked at once a year rather than incident by incident, and a recurring cause is escalated as a deficiency rather than fixed again. [SOC 2: CC7.5, CC4.2]

10 Exercising the Plan

1. The plan is exercised once a year through a tabletop. The exercise confirms the contact list is current, the notification matrix is reachable, and the named external parties still answer. [SOC 2: CC7.5]
2. An hour and a written record is sufficient. What the exercise is for is finding the phone number that no longer works, not rehearsing a script. [SOC 2: CC7.5]

11 Records

1. The event population for the period, including events closed as non-incidents. [SOC 2: CC7.3]
2. Incident records with timelines, containment actions and severity history. [SOC 2: CC7.4]
3. Notification decisions with basis and timing, whether or not notification followed. [SOC 2: CC2.3]
4. Post-incident reviews, and corrective actions carried in the plan of action. [SOC 2: CC7.5]
5. The annual tabletop record and the current contact list. [SOC 2: CC7.5]

12 Exceptions

Where a requirement of this Policy cannot be met during an incident, the departure is recorded in the incident record with the reason, rather than raised as an exception afterwards. Standing exceptions are recorded by the Accountable Party with a review date.

13 Reference

1. SOC 2 Trust Services Criteria, Security category [CC2.2, CC2.3, CC7.3, CC7.4, CC7.5]
2. POL-ISP-001 Information Security Policy [SOC 2: CC4.2]
3. POL-LOG-001 Logging and Monitoring Policy [SOC 2: CC7.2]
4. POL-AI-001 Artificial Intelligence Governance Policy [SOC 2: CC7.3]
5. POL-COC-001 Code of Conduct [SOC 2: CC2.2]
6. POL-BCP-001 Business Continuity Policy [SOC 2: CC9.1]
7. HIPAA Security Rule, 45 CFR §164.308(a)(6)
8. EU General Data Protection Regulation, Articles 33 and 34

14 Document Policy History

Version	Date	Description
1.0	August 18, 2026	Initial policy release

135